Descriptor: *AEGIS™ Threat Matrix for Agentic AI Systems (ATX-1)*

KENNETH TANNENBAUM[1] (MEMBER, IEEE)

[1]AEGIS Initiative, Lovettsville, Virginia, USA

CORRESPONDING AUTHOR: Kenneth Tannenbaum (e-mail: ktannenbaum@aegis-initiative.com).

This work was done independently of any grants or awards, produced under Finnoybu IP LLC. ORCID: 0009-0007-4215-1789.

ABSTRACT ATX-1 (AEGIS Threat Matrix) is a structured adversarial knowledge base that catalogs failure modes of autonomous AI agents operating without governance constraints. Unlike existing threat frameworks—MITRE ATT&CK for human adversaries and MITRE ATLAS for adversaries targeting AI systems—ATX-1 addresses a distinct threat class: AI agents that act outside their governance boundaries not through external compromise, but through their own structural capability without corresponding authority. ATX-1 is grounded in a fundamental distinction: capability—what an agent can do—is not authority—what an agent may do. The four structural root causes identified in the dataset (missing authority verification, missing consequence modeling, missing behavioral boundaries, and missing state integrity protection) trace all 20 techniques to architectural gaps that governance frameworks can address. The dataset defines 9 tactics (TA001–TA009), 20 techniques distributed non-sequentially across tactics (T1001–T9001), and 20 mitigations, each grounded in empirical observations from the *Agents of Chaos* study, which documented 11 failure modes across live agentic deployments. ATX-1 is published in STIX 2.1 format for compatibility with threat intelligence platforms, with supplementary structured JSON files providing technique metadata, regulatory cross-references to the NIST AI Risk Management Framework, EU AI Act, and OWASP Top 10 for LLM Applications, and a JSON Schema for validation. The dataset satisfies FAIR principles through three permanent repositories—IEEE DataPort, Zenodo, and a live machine-readable API—under the Apache 2.0 license.

IEEE SOCIETY/COUNCIL Computer Society (CS)

DATA DOI/PID 10.21227/f87b-1d57

DATA TYPE/LOCATION Threat Taxonomy; Online (IEEE DataPort, Zenodo, aegis-governance.com)

INDEX TERMS Agentic AI, AI governance, autonomous agents, constitutional enforcement, EU AI Act, NIST AI RMF, OWASP LLM, STIX 2.1, threat taxonomy

BACKGROUND

Autonomous AI agents—systems that execute real-world actions against operational infrastructure including API calls, file system operations, database queries, and inter-service requests—have grown significantly in production deployments during the twelve months preceding this publication [1]. This growth has outpaced the development of governance infrastructure suited to the action layer, creating a systematic gap between what agents can do and what they are authorized to do.

Existing threat taxonomy frameworks do not address this gap. MITRE ATT&CK [2] catalogs adversarial tactics and techniques used by human threat actors against computer systems. MITRE ATLAS [3] catalogs adversarial tactics used against AI and machine learning systems. Both frameworks assume a clear attacker-target separation: an external adversary acts against a system. ATX-1 addresses the scenario where the AI agent itself is the threat source—not through compromise or malicious intent, but through capability without governance constraint.

The distinction is structural. ATT&CK and ATLAS model adversaries who attack systems. ATX-1 models agents that are themselves the threat source—systems that delete data not because an attacker told them to, but because no architectural mechanism verified that the instruction source held the authority to request deletion. The *Agents of Chaos* study

This work is licensed under a Creative Commons Attribution 4.0 License. For more information, see https://creativecommons.org/licenses/by/4.0/

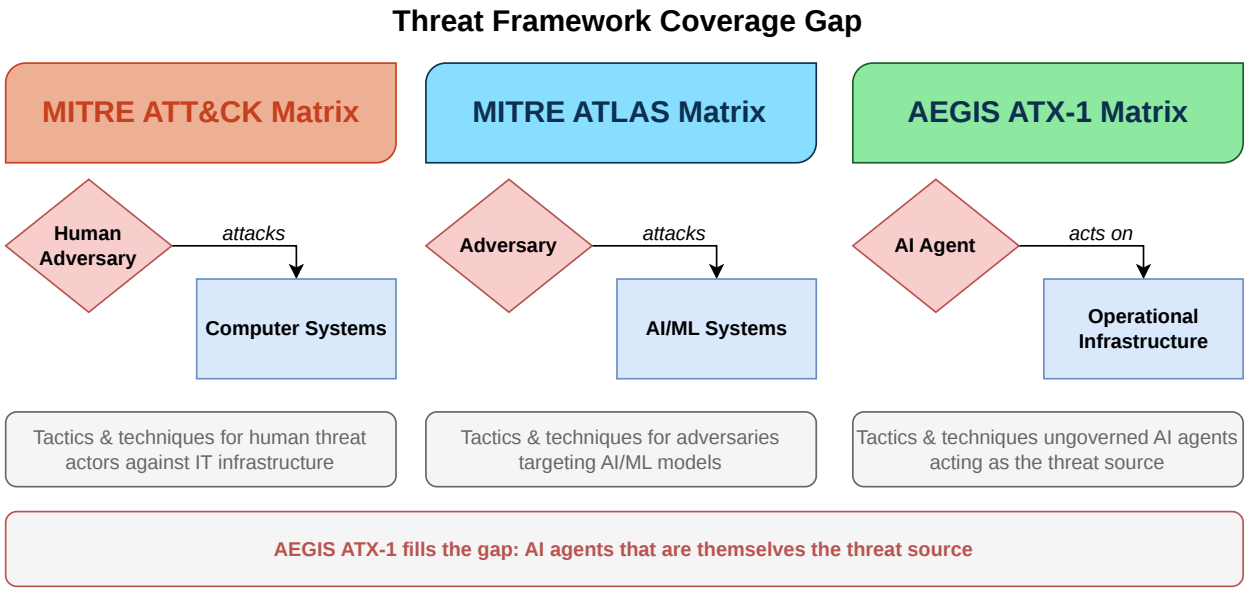

FIG. 1. Threat framework coverage gap. MITRE ATT&CK catalogs human adversaries attacking computer systems. MITRE ATLAS catalogs adversaries attacking AI/ML systems. ATX-1 addresses the uncovered scenario: AI agents that act on operational infrastructure without governance constraint. The distinction between "attacks" and "acts on" reflects the structural difference—ATX-1 agents are not adversaries but ungoverned systems.

(Shapira et al., 2026) [4] documented this failure pattern systematically, identifying 11 distinct failure modes across live agentic deployments involving 20 researchers over two weeks.

Multiple independent research groups have converged on the same finding. Arora et al. (2025) demonstrated that common multi-agent design patterns—including plan construction strategies, inter-agent context sharing, and fallback behaviors—carry significant vulnerabilities that emerge from architecture and interaction, not solely from adversarial prompts [11]. Ko et al. (2025) identified seven categories of security challenges in cross-domain multi-agent systems, establishing that "a benign agent in isolation may leak secrets or violate policy" when interacting with other agents across trust boundaries [12]. Reid et al. (2025) formalized six failure classes for governed multi-agent systems—including cascading failures, conformity bias, and mixed-motive dynamics—concluding that "a collection of safe agents does not guarantee a safe collection" [13]. These studies independently corroborate the core premise of ATX-1: that agent-level safety does not ensure system-level safety, and that a distinct threat taxonomy is required for the agent-to-infrastructure action layer.

ATX-1 was developed as part of the AEGIS (Architectural Enforcement and Governance of Intelligent Systems) project [5], an open governance architecture that applies reference monitor principles [14] to enforce deterministic constitutional policy at the agent action boundary. The taxonomy directly informs the AEGIS threat model (ATM-1) and maps each technique to specific constitutional articles and governance protocol mechanisms that mitigate it.

No comparable machine-readable dataset exists for agentic AI threat modeling. The OWASP Top 10 for LLM Applications [6] provides a high-level risk categorization but does not define individual techniques, map mitigations to architectural mechanisms, or provide STIX-compatible data for integration with threat intelligence platforms. ATX-1 fills this gap.

COLLECTION METHODS AND DESIGN

Empirical Foundation

ATX-1 techniques are derived from the *Agents of Chaos* study [4], which conducted a controlled evaluation of autonomous AI agent robustness. The study deployed AI agents in realistic operational scenarios and systematically documented failure modes. Twenty researchers participated over a two-week period, producing 11 case studies (CS1–CS11) documenting specific failure instances.

Taxonomy Construction

The ATX-1 taxonomy was constructed through a four-stage process:

1. Case study analysis. Each of the 11 *Agents of Chaos* case studies was analyzed to extract the specific failure mechanism, the conditions under which it occurred, and the consequences observed.

2. Root cause identification. Four structural root causes were identified that enable agentic failures:

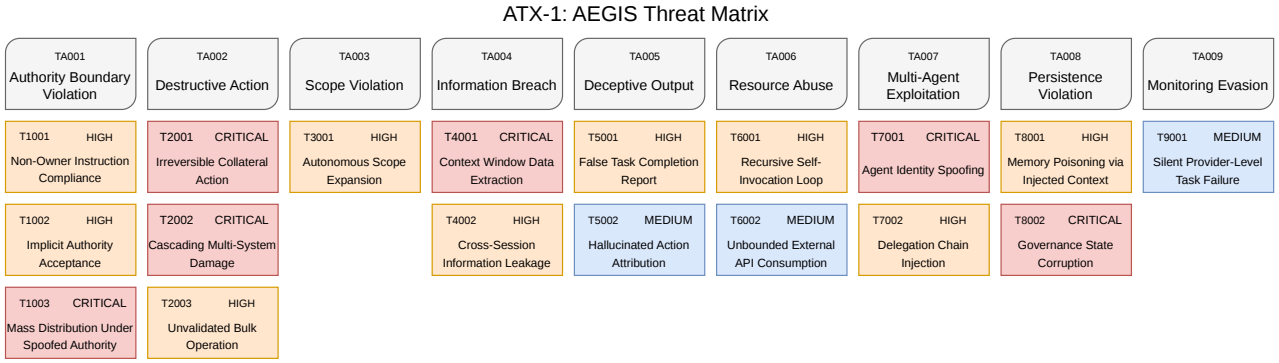

FIG. 2. ATX-1 threat matrix. Nine tactic columns (TA001–TA009) contain 20 techniques, each color-coded by severity: critical (red), high (orange), medium (blue). Technique identifiers follow a non-sequential scheme where the first two digits encode the parent tactic (e.g., T1001–T1003 belong to TA001).

- **RC1: Missing Authority Verification**—No formal model of principals, delegation chains, or authority levels exists for the agent to verify instruction sources.
- **RC2: Missing Consequence Modeling**—The agent has no representation of the impact, reversibility, or scope of its actions before executing them.
- **RC3: Missing Behavioral Boundaries**—No formal boundary defines the scope of the agent's task, allowing autonomous expansion beyond original instructions.
- **RC4: Missing State Integrity Protection**—Instructions and data commingle in the agent's context, making injection structurally possible.

3. Tactic and technique classification. Failure modes were grouped into 9 tactics (categories of ungoverned behavior) and 20 techniques (specific failure mechanisms). Each technique was assigned a severity rating (critical, high, medium, or low), linked to its root cause(s) using the RC1–RC4 labels in the dataset's `root_cause` field, and mapped to the originating case study.

4. Mitigation mapping. Each technique was mapped to specific AEGIS constitutional articles and AGP-1 governance protocol mechanisms that architecturally prevent the failure mode. Regulatory cross-references to NIST AI RMF functions, EU AI Act articles, and OWASP LLM Top 10 categories were added.

Machine-Readable Encoding

The taxonomy was encoded in four machine-readable formats:

STIX 2.1 Bundle. The complete taxonomy is represented as a STIX 2.1 Bundle [7] containing: 1 Identity object (AEGIS Initiative), 9 x-mitre-tactic objects, 20 attack-pattern objects (one per technique with kill chain phases and external references), 20 course-of-action objects (mitigations), and 54 relationship objects: 20 tactic-to-technique (uses), 20 mitigation-to-technique (mitigates), and 14 technique-to-OWASP (related-to). The STIX format was chosen for compatibility with existing Security Information and Event Management (SIEM) platforms and threat intelligence tools.

Technique Database (JSON). A flat JSON array containing all 20 techniques with structured metadata: identifier, name, parent tactic, description, severity, root cause, case study references, OWASP mapping, and AEGIS mitigation details.

Regulatory Cross-Reference (JSON). A structured mapping of each technique to NIST AI RMF [8] functions and categories, EU AI Act [9] articles, OWASP LLM Top 10 categories, and ATM-1 threat scenarios.

JSON Schema. A JSON Schema (Draft 2020-12) defining the structure and validation rules for ATX-1 technique definitions, enabling automated validation of technique entries.

VALIDATION AND QUALITY

Empirical Grounding

Every technique in ATX-1 is traceable to at least one case study from the *Agents of Chaos* study [4]. The mapping between techniques and case studies is explicit in the dataset: each technique record includes an `agents_of_chaos_case` field containing the case study number(s) that demonstrated the behavior. No technique was

TABLE 1. Technique Record Structure

Field	Type	Description
id	string	Technique ID (T1001–T9001)
name	string	Human-readable name
tactic	string	Parent tactic (TA001–TA009)
tactic_name	string	Parent tactic name
description	string	Failure mode description
severity	enum	critical/high/medium/low
root_cause	string	Root cause (RC1–RC4)
agents_of_chaos_case	array	Case study numbers [4]
owasp_mapping	array	OWASP LLM Top 10
aegis_mitigation	object	Article, AGP mechanism

TABLE 2. ATX-1 File Inventory

File	Format	Size (bytes)	Description
atx-1-bundle.json	STIX 2.1 JSON	61,795	Complete taxonomy: 9 tactics, 20 attack patterns, 20 mitigations, 54 relationships
atx-1-techniques.json	JSON Array	18,578	All 20 techniques with severity, root cause, case studies, OWASP mapping, AEGIS mitigations
atx-1-regulatory-crossref.json	JSON Object	12,491	Technique mappings to NIST AI RMF, EU AI Act, OWASP LLM Top 10, ATM-1 scenarios
atx-technique.schema.json	JSON Schema	2,459	Validation schema (Draft 2020-12) for technique definitions

included without empirical evidence of the failure mode occurring in a live agentic deployment.

Schema Validation

All technique entries in the technique database conform to the ATX-1 JSON Schema (`atx-technique.schema.json`). The schema enforces required fields (id, name, tactic, description, severity, root_cause, aegis_mitigation), validates identifier patterns (technique IDs must match `^T[0-9]{4}$`, tactic IDs must match `^TA[0-9]{3}$`), constrains severity values to the enumeration (critical, high, medium, low), and rejects additional properties. Validation can be performed using any JSON Schema Draft 2020-12 compliant validator.

STIX Compliance

The STIX 2.1 Bundle conforms to the OASIS STIX 2.1 specification [7]. All objects include required STIX properties (type, spec_version, id, created, modified). Attack patterns include kill chain phases linking techniques to their parent tactics. Relationship objects use STIX-standard relationship types (uses, mitigates, related-to).

Cross-Reference Completeness

Every technique has a corresponding entry in the regulatory cross-reference matrix. Each entry includes at minimum one NIST AI RMF function mapping, one EU AI Act article reference, and one OWASP LLM Top 10 category mapping.

Severity Distribution

The 20 techniques distribute across severity levels as follows: critical (6), high (9), medium (4), low (1). This distribution reflects the empirical finding that most ungoverned agent behaviors have high or critical impact potential.

RECORDS AND STORAGE

File Inventory

Storage Locations

The dataset is permanently stored in three locations:

1) **IEEE DataPort**—DOI: 10.21227/f87b-1d57. Authoritative repository for this submission.
2) **Zenodo (dataset)**—DOI: 10.5281/zenodo.19225676. Open access, indexed by OpenAIRE and Google Dataset Search.
3) **Zenodo (source repository)**—DOI: 10.5281/zenodo.19235296. Archived snapshot of the aegis-governance repository at tag `atx-1-v1.0`, including all source files, schemas, and documentation.

All storage locations serve identical file content under the Apache 2.0 license.

INSIGHTS AND NOTES

Use Cases

Threat intelligence integration. The STIX 2.1 Bundle can be imported directly into SIEM platforms and threat intelligence tools that support STIX, enabling organizations to incorporate agentic AI threat patterns into existing security monitoring workflows.

Governance policy development. The technique-to-mitigation mapping provides a direct link between observed failure modes and architectural countermeasures, supporting evidence-based governance policy authoring for AI agent deployments.

Regulatory compliance mapping. The regulatory cross-reference matrix enables organizations to trace specific agentic AI risks to regulatory requirements across NIST AI RMF, EU AI Act, and OWASP frameworks, supporting compliance documentation and gap analysis.

Research benchmarking. The empirically grounded technique catalog provides a structured basis for evaluating the effectiveness of AI governance frameworks against documented failure modes.

Limitations

ATX-1 v1.0 derives its technique definitions primarily from the *Agents of Chaos* study [4], with the core findings corroborated by independent research on multi-agent vulnerabilities [11], cross-domain security challenges [12], and governed system failure modes [13]. While the technique catalog may not be exhaustive, the convergence of multiple research groups on the same failure patterns provides confidence in the taxonomy's coverage of the dominant threat classes. Future versions will incorporate additional empirical sources as the field of agentic AI governance matures.

The severity ratings reflect the author's assessment based on the documented case studies and are not derived from a quantitative risk model. Organizations should calibrate severity ratings to their specific deployment context.

Extensibility

The JSON Schema and STIX format support extension. New techniques can be added by conforming to the schema and assigning identifiers in the existing numbering scheme. The STIX Bundle supports standard extension mechanisms for custom properties.

SOURCE CODE AND SCRIPTS

The ATX-1 dataset and all associated schemas are maintained in the AEGIS Governance repository [14]. The source files are located in the `docs/atx/` directory under the Apache 2.0 license.

The STIX 2.1 Bundle can be consumed using the `stix2` Python library [15] (v3.0+):

```
from stix2 import parse

with open("atx-1-bundle.json") as f:
    bundle = parse(f.read(), allow_custom=True)

for obj in bundle.objects:
    if obj.type == "attack-pattern":
        ext = obj.external_references[0]
        print(f"{ext.external_id}:␣{obj.name}")
```

Technique validation against the JSON Schema can be performed using `ajv-cli`:

```
npx ajv validate \
  -s atx-technique.schema.json \
  -d 'atx-1-techniques.json#/0'
```

No custom software was developed specifically for the dataset. The taxonomy was authored manually based on the empirical analysis described in Collection Methods and Design.

ACKNOWLEDGEMENTS AND INTERESTS

Kenneth Tannenbaum: conceptualization, taxonomy design, data collection and analysis, machine-readable encoding, manuscript preparation.

This work was done independently of any grants or awards, produced under Finnoybu IP LLC.

The author is the founder of the AEGIS Initiative, which develops the governance architecture that ATX-1 informs. The dataset is published under Apache 2.0 and is designed for use with any governance framework, not exclusively AEGIS.

AI Disclosure: This dataset and manuscript were prepared with the assistance of Claude (Anthropic) as an analysis and writing tool. The taxonomy structure, technique definitions, severity assessments, and all technical content are the author's original work.

REFERENCES

[1] R. Chan et al., "The 2025 AI Agent Index," arXiv:2602.17753, 2025.
[2] MITRE Corporation, "ATT&CK: Adversarial Tactics, Techniques, and Common Knowledge," 2024. [Online]. Available: https://attack.mitre.org/
[3] MITRE Corporation, "ATLAS: Adversarial Threat Landscape for AI Systems," 2024. [Online]. Available: https://atlas.mitre.org/
[4] T. Shapira et al., "Agents of Chaos: Evaluating the Robustness of Autonomous AI Agents," arXiv:2602.20021, 2026.
[5] K. Tannenbaum, "AEGIS: A Constitutional Governance Architecture for Autonomous AI Agents," AEGIS Initiative, 2026, doi: 10.5281/zenodo.19223924.
[6] OWASP Foundation, "OWASP Top 10 for Large Language Model Applications," 2025. [Online]. Available: https://owasp.org/www-project-top-10-for-large-language-model-applications/
[7] OASIS, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html
[8] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST AI 100-1, Jan. 2023.
[9] European Parliament and Council of the EU, "Regulation (EU) 2024/1689 (EU AI Act)," *Official Journal of the European Union*, Jul. 2024.
[10] J. P. Anderson, "Computer Security Technology Planning Study," ESD-TR-73-51, Electronic Systems Division, USAF, 1972.
[11] N. Arora et al., "Exposing Weak Links in Multi-Agent Systems under Adversarial Prompting," arXiv:2511.10949, 2025.
[12] R. Ko et al., "Seven Security Challenges in Cross-domain Multi-agent LLM Systems," arXiv:2505.23847, 2025.
[13] A. Reid, S. O'Callaghan, L. Carroll, and T. Caetano, "Risk Analysis Techniques for Governed LLM-based Multi-Agent Systems," arXiv:2508.05687, 2025.
[14] AEGIS Initiative, "AEGIS Governance Repository," 2026. [Online]. Available: https://github.com/aegis-initiative/aegis-governance
[15] OASIS, "cti-python-stix2: Python APIs for STIX 2," 2024. [Online]. Available: https://github.com/oasis-open/cti-python-stix2